

Botium Toys: Escopo, objetivos e relatório de avaliação de riscos

Âmbito e objetivos da auditoria

Escopo: O escopo é definido como todo o programa de segurança da Botium Toys. Isso significa que todos os ativos precisam ser avaliados juntamente com os processos e procedimentos internos relacionados à implementação de controles e melhores práticas de conformidade.

Objetivos: Avaliar os ativos existentes e preencher a lista de verificação de controles e conformidade para determinar quais controles e melhores práticas de conformidade precisam ser implementadas para melhorar a postura de segurança da Botium Toys.

Ativos circulantes

Os ativos gerenciados pelo Departamento de TI incluem:

- Equipamentos instalados no local para atender às necessidades de negócios no escritório.
- Equipamentos dos funcionários: dispositivos do usuário final (desktops/laptops, smartphones), estações de trabalho remotas, fones de ouvido, cabos, teclados, mouses, estações de acoplamento, câmeras de vigilância, etc.
- Produtos da loja disponíveis para venda no local e online; armazenados no armazém adjacente da empresa.
- Gestão de sistemas, software e serviços: contabilidade, telecomunicações, bases de dados, segurança, comércio eletrônico e gestão de inventário.
- acesso à Internet
- Rede interna
- Retenção e armazenamento de dados
- Manutenção de sistemas legados: sistemas em fim de vida útil que requerem monitoramento humano.

Avaliação de risco

Descrição do risco

Atualmente, a gestão de ativos é inadequada. Além disso, a Botium Toys não possui todos os controles adequados e pode não estar em total conformidade com as normas e regulamentações americanas e internacionais.

Melhores práticas de controle

A primeira das cinco funções do NIST CSF é a Identificação. A Botium Toys precisará dedicar recursos para identificar seus ativos, de forma a gerenciá-los adequadamente. Além disso, precisará classificar os ativos existentes e determinar o impacto da perda desses ativos, incluindo sistemas, na continuidade dos negócios.

Pontuação de risco

Em uma escala de 1 a 10, a pontuação de risco é 8, o que é bastante alto. Isso se deve à falta de controles e à não adesão às melhores práticas de conformidade.

Comentários adicionais

O impacto potencial da perda de um ativo é classificado como médio, pois o departamento de TI desconhece quais ativos estariam em risco. O risco para os ativos ou multas por parte dos órgãos reguladores é alto, visto que a Botium Toys não possui todos os controles necessários implementados e não está em total conformidade com as melhores práticas relacionadas às regulamentações que mantêm os dados críticos privados e seguros. Consulte os seguintes tópicos para obter detalhes específicos:

- Atualmente, todos os funcionários da Botium Toys têm acesso a dados armazenados internamente e podem ter acesso a dados de titulares de cartões e informações pessoais identificáveis/informações sensíveis de clientes.
- Atualmente, a criptografia não é utilizada para garantir a confidencialidade das informações de cartão de crédito dos clientes que são aceitas, processadas, transmitidas e armazenadas localmente no banco de dados interno da empresa.
- Os controles de acesso relativos ao princípio do menor privilégio e à segregação de funções não foram implementados.
- O departamento de TI garantiu a disponibilidade e integrou controles para assegurar a integridade dos dados.
- O departamento de TI possui um firewall que bloqueia o tráfego com base em um conjunto de regras de segurança adequadamente definidas.

- O departamento de TI instala e monitora regularmente o software antivírus.
- O departamento de TI não instalou um sistema de detecção de intrusões (IDS).
- Atualmente, não existem planos de recuperação de desastres em vigor, e a empresa não possui backups de dados críticos.
- O departamento de TI estabeleceu um plano para notificar os clientes da UE em até 72 horas em caso de violação de segurança. Além disso, políticas, procedimentos e processos de privacidade foram desenvolvidos e são aplicados entre os membros do departamento de TI e demais funcionários, para documentar e manter os dados adequadamente.
- Embora exista uma política de senhas, seus requisitos são nominais e não estão em conformidade com os requisitos mínimos atuais de complexidade de senha (por exemplo, pelo menos oito caracteres, uma combinação de letras e pelo menos um número; caracteres especiais).
- Não existe um sistema centralizado de gerenciamento de senhas que imponha os requisitos mínimos da política de senhas, o que às vezes afeta a produtividade quando funcionários/fornecedores abrem um chamado para o departamento de TI para recuperar ou redefinir uma senha.
- Embora os sistemas legados sejam monitorados e recebam manutenção, não existe um cronograma regular para essas tarefas e os métodos de intervenção não são claros.
- As instalações físicas da loja, que incluem os escritórios principais da Botium Toys, a fachada da loja e o depósito de produtos, possuem fechaduras suficientes, sistema de vigilância por circuito fechado de televisão (CFTV) atualizado, além de sistemas de detecção e prevenção de incêndio em pleno funcionamento.